

Banking platform standards (access, registry, DR, naming, security gates)

Banking platform standards v1 (opinionated industry baseline)

Purpose: Fill all missing deliverable information with prescriptive, banking-sector defaults where client discovery is incomplete. **SOW items 2, 4, 5, 6.** Client platform approves deviations in writing.

Companion docs: (technical RHEL/Podman)

Industry authorities:

1. Access and identity (human + machine)

Rule	Industry standard (banking)	This engagement default
Interactive Linux	Individual Entra ID per engineer — no shared <code>admin / deploy</code>	Entra ID SSH or Bastion + per-user <code>sudo</code>
Privilege elevation	PIM eligible roles; MFA; ≤8h activation; justification required	Dev sub: Reader + AcrPush + KV Secrets User via PIM
VM workload auth	One UAMI per VM — runner ≠ runtime	<code>AcrPush / AcrPull</code> split
Break-glass	Named account in sealed envelope; logged ; post-incident access review within 24h	Client SOC owns process
Consultant / vendor	Guest Entra; PIM Reader only; removed 5 business days after engagement	
SSH keys	Prohibited password auth; prohibited shared keys in email/ClickUp	<code>PasswordAuthentication</code> no
Sudo	<code>wheel</code> via Entra group; NOPASSWD denied on UAT/prod	Client IAM group <code>grp-linux-sudo-{env}</code>

Anti-patterns (reject): shared admin, permanent Contributor for vendors, service principal secrets on laptops, `az login` with user creds on UAT/prod VMs.

2. Container registry and supply chain

Decision	Opinionated standard	Rationale
Registry	Azure Container Registry Premium	Private endpoint, content trust, quarantine, geo-replication, Azure RBAC + UAMI — aligns with FFIEC third-party / data-flow controls
GHCR	Dev-only fallback if ACR not ready in Phase 1; migrate to ACR before UAT	External registry increases egress review and secret handling
Admin user	Disabled	ACR admin creds are audit findings
Public access	Disabled	Pull via PE + UAMI only
Image signing	Required before prod — Notation/cosign or ACR content trust	Supply-chain control (NIST 800-53 SI-7)
Base images	UBI9 or RHA1 from <code>registry.redhat.io</code> via pull-through cache in ACR	Supported, patchable, RHSM-aligned
Tagging	<code>{app}:{git-sha}</code> immutable; <code>{app}:{env}-latest</code> mutable pointer	Rollback = redeploy prior sha
Promotion	dev → UAT → prod via GitHub Environments + required reviewers	No manual <code>podman tag</code> on runtime
Vulnerability scan	ACR Defender or Trivy in CI; block prod promote on CRITICAL unfixed	See §10 gates
Retention	30-day untagged purge; keep last 10 tagged releases per app	Cost + forensics balance

Reference IaC: `infra/terraform/modules/acr-baseline/`, `build/images.manifest.json`

Full advisory:

3. Podman runtime (opinionated)

Rule	Standard
Runtime	Podman 4.x+ on RHEL 9 — no Docker daemon
Mode	Rootful on dedicated runtime VM (banking default for volume/SELinux predictability); rootless only if GRC mandates separation
Orchestration	Quadlet (<code>.container</code> , <code>.network</code> , <code>.volume</code>) — not raw <code>podman run</code> in cron
Restart	<code>Restart=always</code> in quadlet; <code>systemctl enable --now</code>
Graph root	<code>/var/lib/containers</code> on managed data disk (not OS disk)
SELinux	<code>container_file_t</code> contexts documented per volume; <code>:Z</code> only where required; booleans in standards appendix
Published ports	nginx sidecar only on <code>8080</code> — app containers bind <code>127.0.0.1</code> or internal network
Pull policy	<code>PullPolicy=newer</code> or explicit digest pin in quadlet for prod
Secrets	Key Vault → <code>podman secret</code> or env file from <code>az keyvault secret show</code> at deploy — never in image
Health	<code>HEALTHCHECK</code> in image + <code>systemd ExecStartPost curl to /health</code>
Logs	<code>journald</code> per container; forward via AMA syslog

4. CI/CD and promotion

Rule	Standard
Build location	Runner VM only — never on runtime
Runner trust	Lower trust zone — runner UAMI cannot pull prod secrets unrelated to build
Branch model	<code>main</code> → dev auto; <code>release/*</code> → UAT; tag v* → prod (manual approval)
Concurrency	One deploy per env (<code>concurrency: group: deploy-uat</code>)
OIDC	Prefer GitHub OIDC → Azure for workflow Azure steps; UAMI for <code>podman push</code> on host
Deploy to runtime	Workflow SSH/Ansible or pull-only systemd refresh on runtime — runtime never clones git
Rollback	Redeploy previous git-sha from ACR; max rollback window 4h after prod deploy
Secrets in GHA	OIDC + KV — no long-lived <code>AZURE_CLIENT_SECRET</code> in repo secrets

5. Backup, DR, and business continuity

Item	Banking default	Owner
Runtime data disk	Azure Backup daily + ASR replication to paired region	Client
Runner VM	Rebuild from IaC acceptable — no ASR unless build cache is irreplaceable	Client
RPO (runtime)	4 hours for ingestion paths; 24 hours for stateless APIs unless business dictates lower	Client PM + BCP
RTO (runtime)	4 hours ASR failover; 8 hours rebuild-from-IaC	Client
DR test	Annual ASR test minimum; quarterly for tier-1 trading-adjacent paths	Client
Podman volumes	On data disk — included in backup scope; document paths in CMDB	
Key Vault	Soft-delete + purge protection; geo-redundant if policy requires	Client
SIG versions	Retain 3 image versions; rebuild VMs from SIG on OS CVE emergency	Client platform

6. Patching and change management

Item	Standard
OS security	dnf-automatic security-only daily; full validation monthly maintenance window
Reboot	Scheduled monthly window; no auto-reboot from dnf-automatic
Container images	Rebuild on base image CVE or app release — not on OS patch alone
CAB	Standard change for UAT/prod deploy; emergency for P0 CVE with retroactive CAB within 48h
Freeze	No prod changes last 3 business days of quarter-end unless emergency
Evidence	Change ticket ID in git tag message and deployment log

7. Monitoring, logging, and alerting

Signal	Tool (banking stack)	Alert threshold (default)
OS metrics	Azure Monitor AMA + Logic Monitor	CPU >85% 15m; disk >80%
Syslog/auth	Azure Monitor DCR → Log Analytics / Sentinel	Failed SSH >5/5m from non-Bastion
systemd failed units	Logic Monitor or AMA custom	Any failed unit on runtime >5m
Podman container down	Logic Monitor process check	Critical service down >2m
ACR pull failures	ACR diagnostics	Any prod pull failure
GitHub runner queue	Runner metrics / workflow	Queue >30m

SIEM: Client routes Log Analytics to Sentinel/Splunk — consultant does not write detections.

8. Naming, tagging, and IPAM

Azure naming

```
{org}-{env}-{region}-{role}-{seq}
```

Component	Example
Runner VM	fd-dev-eus-github-runner-01
Runtime VM	fd-dev-eus-podman-runtime-01
UAMI	uami-fd-dev-github-runner
ACR	fddevacr (globally unique, no hyphens)
Key Vault	kv-fd-dev-eus-01

Required tags

Tag	Values
Environment	dev , uat , prod
CostCenter	Client finance code
DataClassification	internal , confidential , restricted
Owner	Platform team email
ManagedBy	terraform or manual
ComplianceScope	ffiec , sox , none

IPAM

Role	Allocation rule
Runner	/28 minimum; static IP documented in firewall
Runtime	/28 minimum; static IP
Reserve	+2 IPs per subnet for future HA

9. VM sizing (starting SKUs — validate against assessment)

Role	Dev (start)	UAT	Prod
Runner	Standard_D4s_v5 (4 vCPU, 16 GiB)	D4s_v5	D8s_v5 if parallel builds
Runtime	Standard_D8s_v5 (8 vCPU, 32 GiB)	D8s_v5	D16s_v5 if Dagster + ingestion peak
OS disk	64 GiB Premium	64 GiB	64 GiB
Data disk (runtime)	256 GiB Premium	512 GiB	1 TiB Premium (ingestion)

Rule: Right-size from 2-week metrics before UAT/prod purchase.

10. Security gates (vulnerability and compliance)

Gate	When	Rule
P0	Before UAT template	Zero open P0 on Linux from pen test / Arctic Wolf
P1	Before prod	Documented exception or remediated
CRITICAL CVE	CI/CD	Block image push to <code>prod</code> ACR repo
CIS L1	SIG promotion	OpenSCAP pass with ≤ 5 documented exceptions
STIG	Only if GRC mandates	Separate profile — not stacked with CIS L1
Prod cutover	Go/no-go	Security sign-off (Client security) + platform + app owner

11. Break-glass and emergency access

Step	Standard
Trigger	P1 outage + PIM approvers unavailable
Account	Pre-provisioned individual break-glass Entra account per env
Activation	Two-person rule (platform + security)
Duration	4 hours max; auto-disable after
Post-incident	Ticket, log review, credential rotation within 24h

12. Data classification and egress

Data path	Classification	Control
Snowflake	Confidential	TLS 1.2+; private egress via firewall
SFTP ingestion	Restricted	IP allow-list; no Internet egress from runtime except allow-list
Charles River	Restricted	Named FQDN allow-list only
GitHub (runner)	Internal	Egress allow-list

13. Client decisions required (record sign-off)

ID	Decision	Default if no response by week 4
D1	CIS L1 vs STIG	CIS L1
D2	ACR vs GHCR	ACR Premium
D3	Rootful vs rootless Podman	Rootful on runtime VM
D4	nginx sidecar vs APIM	nginx sidecar until APIM chartered
D5	WSL dev vs RHEL dev VM	WSL allowed ; prod path uses RHEL VMs
D6	RPO/RTO	4h / 4h runtime ASR

Related deliverables

Doc	SOW item
	1, 4
	4
	2, 4
	6
	5, 6

Industry references

Full map:

Section	Primary sources
§1 Access	FFIEC IS Handbook NIST SP 800-207 Zero Trust Entra PIM
§2 Registry	ACR best practices NIST SP 800-190 SLSA
§3 Podman	Podman docs Quadlet Red Hat container SELinux
§4 CI/CD	GitHub Environments CIS Controls v8
§5 DR	Azure Backup Azure Site Recovery
§6 Patching	FFIEC patch management dnf-automatic
§7 Monitoring	Azure Monitor MCSB logging
§10 Security gates	CIS RHEL 9 Defender for Containers